

CO3 - AT3

allow database query logic. Attacker can bypass authentication ('OR'1' = '1'), extract tabular data via UNION SELECT, or alter records.

Cross-site Scripting (XSS):

Arises when untrusted scripts are reflected, or stored within a reflected or stored within web responses. Attacker executes javascript in victim's sessions to exfiltrate cookies or perform client-side actions.

Audit Methodology with Burp suite & SQLMap:

1. Request Interception (Burp suite):

Route initial transaction traffic through the local proxy.

Identify POST / database errors or reflect injected strings.

gobuster dir -u http://target

3. Vulnerability Scanning:

Assess baseline server flaws and configuration oversights using specialized web scanners:

nikto -h http://target -iP>

4. Validation & proof of concept:

Audit flagged input forms through an intercepting proxy to inspect request/response headers, manipulate parameters, and verify if unsanitized data renders in the client response or alters back-end database queries.

Scenario 2:

2. Financial Application SQLi & XSS Audit:

Vulnerability Mechanics & CIA triad impact

SQL injection (SQLi):

Occurs when untrusted user input

Scenario 1: e-commerce web application assessment

& identifying Attack vector analysis

misconfigured Apache server:

unpatched versions often harbor known common vulnerabilities and exposures

(CVEs) such as remote code execution, path traversal, or HTTP request smuggling.

Directory traversal / forced Browsing:

the absence of strict access controls and directory indexing restrictions

enables attackers to probe hidden administrative panels, configuration files.

Reconnaissance:

Identify active services and Apache daemon versions using non-intrusive port.

`nmap -Sv -SC -P 80-443 -targ`

2. web crawling & content discovery.

Map hidden endpoints, directories, and configuration files.

Scenario 3:

Evil Twin Wireless Attack Analysis & Countermeasures

Attack Execution Mechanics

1. Beacon Framing: The attacker broadcasts an identical Service Set Identifier (SSID) on a different wireless channel with a stronger signal.
2. Deauthentication & Reassociation: Attackers transmit Spoofed 802.11 deauthentication frames to disconnect victims from the legitimate Access point (AP), forcing to disconnect automatically roam to the rogue AP.
3. Credential Harvesting: The rogue AP routes traffic through a Captive portal or performs SSL stripping to capture plaintext Credentials

Detection & Analysis (Kali Linux)

- Airmon-ng / Airodump-ng: put wireless interfaces into monitor mode to scan for duplicate BSSIDs or identical SSIDs broadcasting from
- Wireshark Analysis: filter for anomalous 802.11 management frames and verify inconsistent OUI (Organizationally Unique Identifier) vendor bytes on duplicate SSIDs

Countermeasures:

- Transition to WPA2/WPA3-Enterprise (802.1X/EAP-TLS): Replace pre-shared keys with certificate-based mutual authentication. Client
- Wireless Intrusion Prevention Systems: Deploy dedicated sensor nodes to detect unsanctioned MAC/SSID pairings.
- User Training & Endpoint Policies: Restrict endpoints from auto-connecting to open networks and educate staff to report duplicate SSIDs or anomalous

Scenario 4:

Multi-stage Internal Penetration

Testing Chain

- Phase 1: Wireless perimeter Assessment: Intercept 4-way handshake via airodump-ng and assess key strength.
- Phase 2: Internal Reconnaissance: Scan internal subnets to identify hosts and services.
- Phase 3: Web vulnerability Assessment: Inspect the employee portal for broken authentication (session fixation, predictable token values).

- Phase 4: Privilege Escalation Testing:
validate role-based access control (RBAC) boundaries by attempting to access administrative API endpoints.

Defense-in-Depth Framework

- Network Segmentation & Zero Trust:
Place internal management systems in isolated VLANs with strict micro-segmentation; wireless clients must not directly route to corporate.
- Robust Session Management:
Generate cryptographically random 128-bit session identifiers, rotate tokens post-authentication, and enforce idle/absolute timeouts.
- Centralized Identity & Access management (IAM):
Enforce Multi-factor authentication (MFA) and granular RBAC across all internal web services.
Place internal management systems in isolated VLANs with strict micro-segmentation; wireless clients must not directly route to.